

HACKING THE PLANET

HARDWARE HACKING



12

LISTA DE FIGURAS

Figura 1 - Camadas de uma PCB	8
Figura 2 - Face superior do <i>smart plug</i>	9
Figura 3 - Face lateral do <i>smart plug</i>	9
Figura 4 - Face traseira do <i>smart plug</i>	9
Figura 5 - <i>Datasheet</i> do ESP8266.....	10
Figura 6 - CVEs públicas do ESP8266.....	11
Figura 7 - Abrindo o <i>smart plug</i>	11
Figura 8 - Abrindo o <i>smart plug</i>	11
Figura 9 - Visão superior da PCB.....	12
Figura 10 - Visão do ESP8266 pela PCB.....	12
Figura 11 - Identificando as portas de acesso ao ESP8266.....	12
Figura 12 - Visão frontal e traseira do ESP8266	13
Figura 13 – Pinos do ESP8266	13
Figura 14 - Soldando os pinos do ESP8266 frontal.....	13
Figura 15 - Soldando os pinos traseiros do ESP8266.....	14
Figura 16 - Ligando os fios ao <i>the Shikra</i> para <i>dump</i> de <i>firmware</i>	14

SUMÁRIO

<i>HARDWARE HACKING</i>	4
1 INTRODUÇÃO	4
2 RECONHECIMENTO E CONCEITOS	4
3 EQUIPAMENTO PARA TESTES DE HARDWARE	5
4 CONCEITOS BASE PARA O RECONHECIMENTO DE <i>HARDWARE</i>	6
5 RECONHECIMENTO E EXPLORAÇÃO	9
CONCLUSÃO.....	14
REFERÊNCIAS.....	15

HARDWARE HACKING

1 INTRODUÇÃO

A área de exploração ofensiva de dispositivos embarcados possui uma falha enorme em suas definições conceituais. Atualmente, no Brasil, foi amplamente difundido o título de “*hardware hacking*” para toda forma de exploração que envolva um dispositivo embarcado, ou seja, suas conexões *wireless*, placa embarcada, aplicações, APIs e *webservices*. Por mais que cada um destes testes não impliquem em nenhum momento o contato direto com o *hardware*. Esse título, inclusive, extravasa também para o mundo de *Red Team Gadgets* e incorpora os profissionais que sabem manipular essas ferramentas, por mais que não tenham necessariamente conhecimento ou vontade de entender e explorar *hardware*.

Hardware hacking, em outros países e em sua definição inicial, entra como toda forma de exploração que envolva o contato físico com a placa de circuito, ou seja, a análise de interfaces de comunicação, *pin tracing*, engenharia reversa de circuitos integrados, modificações pertinentes no circuito, *glitching*, *tamper bypass*, entre outras técnicas de *hacking* em *hardwares*. Por isso, esse capítulo focará nas técnicas aplicadas de avaliação física de dispositivos embarcados, o que não significa que os outros capítulos devem ser descartados!

2 RECONHECIMENTO E CONCEITOS

Nessa seção, discutiremos como realizar o reconhecimento no *hardware*. Um *hardware* pode conter componentes eletrônicos físicos que incluem microcontrolador, microprocessador, resistor, capacitor, LEDs etc. que fazem um determinado dispositivo funcionar. O processo de reconhecimento de *hardware* consiste em várias etapas como a desmontagem do dispositivo, a análise de seus componentes, a depuração de interfaces de comunicação como UART, JTAG/SWD, identificação dos *chips* e a procura de seus respectivos *datasheets*.

Durante o processo de teste ou pesquisa de segurança em geral, antes de começar a atacar o alvo, temos que ter um conhecimento completo do sistema,

mesmo que seja uma caixa-preta. Esse processo de conferência ajuda a identificar os diferentes componentes que compõem o sistema para que possamos direcionar nossos ataques ao que sabemos e as lacunas que identificamos ao compreendê-lo. No reconhecimento, identificamos peças e conectamos essas peças para obter informações inteligentes que ajudarão a comprometer a segurança do sistema. Ao atacar um dispositivo de *hardware*, precisamos primeiro entender do que o *hardware* é feito, ou seja, quais são os diferentes componentes usados para poder criar uma modelagem de ameaças eficaz. Veremos a seguir quais são as informações básicas derivadas durante este processo.

3 EQUIPAMENTO PARA TESTES DE HARDWARE

Para realizarmos o reconhecimento do *hardware*, muitas vezes, precisamos ter algumas ferramentas a nossa disposição, como:

1. Multímetro:

É uma ferramenta muito importante para *probing* de circuito. Isso nos ajudará a testar todos os componentes e medir a resistência, tensão e nível de corrente e continuidade elétrica entre dois pontos.

2. Ferramentas de soldagem:

As ferramentas de soldagem ajudam a remover e colocar componentes, *jumpers* e pinos na PCB.

3. Jogos de chaves:

Necessário para desmontar o dispositivo. Na atualidade, a desmontagem do dispositivo é uma tarefa bastante difícil, às vezes, os fabricantes usam proteção contra adulteração para evitar que as pessoas tenham acesso aos componentes internos do dispositivo (*tampering*).

4. *Jumpers*:

É um pequeno condutor utilizado para conectar dois pontos de um circuito eletrônico.

5. Soprador térmico:

Interessante para remover e adicionar componentes SMD da placa de circuito.

6. Lupa e *stand*:

A lupa ajuda a identificar nomes pequenos e outros detalhes da placa, enquanto o *stand* auxilia a manter a placa estável para soldagem e outras manipulações do circuito.

4 CONCEITOS BASE PARA O RECONHECIMENTO DE *HARDWARE*

Eletrônica básica é uma das coisas mais importantes para entender se você deseja entrar no mundo de *hacking hardware*. Será preciso entender o que está acontecendo no dispositivo e como qualquer componente dado pode ser explorado. Portanto, aqui veremos alguns componentes eletrônicos básicos e o propósito de usá-los em circuitos.

- Resistor: adiciona resistência entre dois componentes e é medido em ohms.
- Capacitor: carrega e descarrega em determinado intervalo de tempo e é usado para estabilizar o fornecimento de energia no circuito. É medido em farad.
- Indutores: são usados para filtrar e suavizar o ruído de alta frequência no circuito por meio de descarga eletromagnética. É medido em henry.
- IC: circuitos integrados é um conjunto de circuitos eletrônicos em pequenos pedaços de silício.
- LED: diodo emissor de luz.
- EEPROM (memória somente de leitura programável apagável eletricamente): dispositivos embarcados usam este como um meio de armazenamento.
- Cristais: oscilam em uma determinada frequência, semelhante a um *timer*.

- Transformadores: são usados para converter os níveis de tensão. Principalmente usado para converter alimentação CA (corrente alternada) em CC (corrente contínua).
- Diodos: usado para restringir o fluxo de corrente em uma direção.
- Relé: chave que controla (abre e fecha) os circuitos eletromecanicamente.
- Microcontrolador/microprocessador: pequeno computador em um único chip de circuito integrado (IC) de óxido metálico (MOS).
- SoC (*System on Chip*): refere-se a todos os componentes de um computador, ou qualquer outro sistema eletrônico, em um circuito integrado (*chip*). Ele pode conter funções digitais, analógicas e mistas.
- Transistor: usado para amplificar e comutar os sinais e energia elétrica.
- Bateria: converte energia química em energia elétrica.
- Motor: converte energia elétrica em energia mecânica.
- Interruptor: interrompe a corrente.
- PCB: placa de circuito impresso (PCB) é um material não condutor com linhas condutoras impressas ou gravadas.

Outro conceito importante é o de encapsulamentos. Existem diferentes encapsulamentos para os componentes que refletem diretamente com a forma como devemos abordá-los.

Through-hole mount package: este tipo de componente é projetado de forma que os pinos do componente sejam inseridos na PCB e o outro lado do pino da PCB possa ser soldável. Esses tipos de componentes são maiores e mais baratos em comparação com componentes SMD.

Surface mount package: o componente *surface mount* é montado diretamente na superfície da PCB. Este tipo de componente tem tamanho mínimo e leva menos tempo para montar, mas também aumenta a chance de defeitos pela dificuldade na soldagem. Os componentes SMD podem se separar em:

1. SOP (*Small-outline L-leaded packages*).
2. QFP (*Quad flat L-shape packages*).

3. BGA (Ball grid array).

Existem muitos outros conceitos dentro da área de eletrônica e *hardware hacking*, porém os apresentados acima já permitem ter um entendimento e um direcionamento base. Com essas definições na cabeça, vejamos como realizar a primeira fase de todo *pentesting*, o reconhecimento.

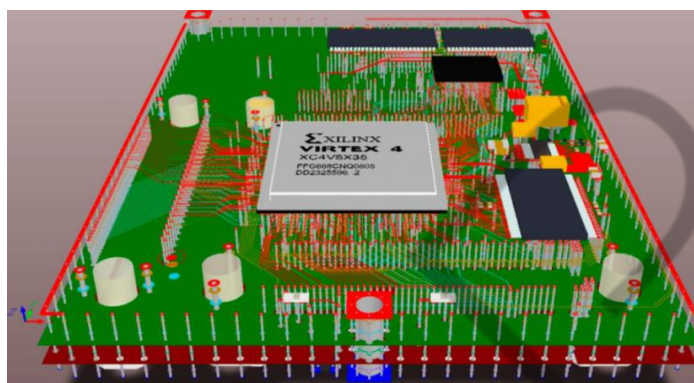


Figura 1 - Camadas de uma PCB
Fonte: Elaborada pela autora (2021)

O reconhecimento de PCBs é um dos passos mais importantes quando se trata de exploração de *hardware*. A placa de circuito impresso (PCB) é um material não condutivo combinado com linhas condutivas impressas ou gravadas. Os componentes eletrônicos da placa da PCB, como os transistores, resistores, capacitores, circuitos integrados (ICs) e as trilhas conectam os componentes para formar um circuito eletrônico. As PCBs são mais comumente feitas de fibra de vidro, epóxi composto ou outro material composto. Elas são compostas de várias camadas, até uma placa simples de lado único (uma camada) é composta de uma camada de metal condutora e uma camada de substrato combinadas. Basicamente, conforme a complexidade da PCB aumenta, também aumenta a quantidade de camadas dentro dela.

A PCB nos dá muitas informações, como diferentes componentes usados, portas de depuração, *pads* de teste etc. Isso permite aos pesquisadores criar um modelo de ameaça/mapa mental de cenários de ataque para o dispositivo.

Sabendo disso, pularemos direto para uma análise prática e definiremos conforme necessário. Você pode acompanhar com um dispositivo eletrônico quebrado ou que tenha a sua disposição, mas saiba que ele pode deixar de funcionar durante o processo.

Eu escolhi o *smart plug* da Positivo como dispositivo de teste.

5 RECONHECIMENTO E EXPLORAÇÃO

Começamos fazendo um reconhecimento externo.

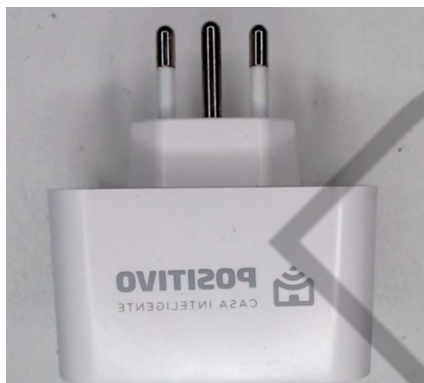


Figura 2 - Face superior do *smart plug*
Fonte: Elaborada pela autora (2021)

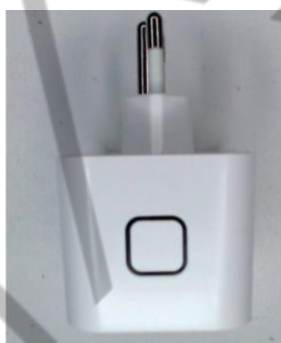


Figura 3 - Face lateral do *smart plug*
Fonte: Elaborada pela autora (2021)



Figura 4 - Face traseira do *smart plug*
Fonte: Elaborada pela autora (2021)

Logo de cara obtemos uma informação interessante. Em **negrito**, no canto inferior direito, está escrito “ESP8266-S3”. Caso este nome não lhe soe familiar, trata-se de um módulo comum em dispositivos para prototipagem rápida (*maker*) e que, inclusive usamos no segundo capítulo para fazer um *keylogger* Wi-fi. Para

termos mais informações sobre ele, podemos procurar o seu *datasheet* no Google. Vejamos este *datasheet*: “<https://fccid.io/2AKBPESP8266-S3/User-Manual/User-Manual-3594791>”.

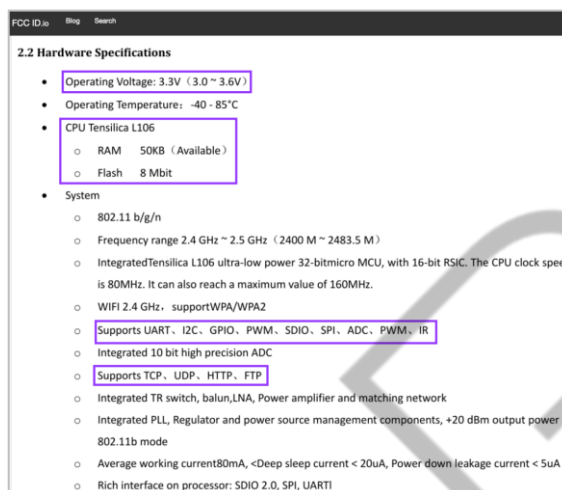


Figura 5 - *Datasheet* do ESP8266
Fonte: Elaborada pela autora (2021)

Lendo o *datasheet*, notamos que o ESP8266 permite diversas interfaces, como I2C, SPI e UART, assim como protocolos TCP, UDP, HTTP e FTP. Percebemos que ele solicita uma tensão de 3.3 V, disponibiliza 50 kB de memória RAM e possui uma CPU com 1 *megabyte* de memória Flash. Com o *datasheet*, temos todas as informações que precisamos sobre o *chip*, inclusive, apenas com o nome do *chip* já poderíamos realizar ataques sem a necessidade de abrir o dispositivo. Por ser um *chip* popular, muitos ataques já foram mapeados, como os reportados pelo pesquisador Matheus Garbelini.

Matheus reportou à Espressif, empresa produtora do ESP8266, em 2017, três vulnerabilidades. A primeira (CVE-2019-12588) explica que a implementação do cliente 802.11 MAC no Espressif ESP8266 NONOS SDK 3.0 e anterior permite que invasores em alcance de rádio causem uma negação de serviço por meio de uma mensagem elaborada. A segunda (CVE-2019-12586) e terceira (CVE-2019-12587) exploram *bugs* na biblioteca do ESP8266 que lida com o protocolo EAP e permitem a um atacante realizar o *hijack* da conexão entre o *access point* e o dispositivo e roubar informações importantes, fazer *replay*, *spoof* e descriptografar o tráfego passado. Podemos pesquisar por vulnerabilidades conhecidas em locais como “<https://cve.mitre.org/>”. Na figura abaixo, são listadas as falhas reportadas

publicamente para o ESP8266, com isso já poderíamos realizar ataques contra o *Smart Plug* da Positivo.

Search Results	
There are 4 CVE Records that match your search.	
Name	Description
CVE-2020-12638	An encryption-bypass issue was discovered on Espressif ESP-IDF devices through 4.2, ESP8266_NONOS_SDK devices through 3.0.3, and ESP8266_RTOS_SDK devices through 3.3. Broadcasting forged beacon frames forces a device to change its authentication mode to OPEN, effectively disabling its 802.11 encryption.
CVE-2019-12588	The client 802.11 mac implementation in Espressif ESP8266_NONOS_SDK 2.2.0 through 3.1.0 does not validate correctly the RSN AuthKey suite list count in beacon frames, probe responses, and association responses, which allows attackers in radio range to cause a denial of service (crash) via a crafted message.
CVE-2019-12587	The EAP peer implementation in Espressif ESP-IDF 2.0.0 through 4.0.0 and ESP8266_NONOS_SDK 2.2.0 through 3.1.0 allows the installation of a zero Pairwise Master Key (PMK) after the completion of any EAP authentication method, which allows attackers in radio range to replay, decrypt, or spoof frames via a rogue access point.
CVE-2019-12586	The EAP peer implementation in Espressif ESP-IDF 2.0.0 through 4.0.0 and ESP8266_NONOS_SDK 2.2.0 through 3.1.0 processes EAP Success messages before any EAP method completion or failure, which allows attackers in radio range to cause a denial of service (crash) via a crafted message.

Figura 6 - CVEs públicas do ESP8266

Fonte: Elaborada pela autora (2021)

Como somos curiosos, entretanto, iremos continuar o nosso reconhecimento e abrir o dispositivo.



Figura 7 - Abrindo o smart plug

Fonte: Elaborada pela autora (2021)



Figura 8 - Abrindo o smart plug

Fonte: Elaborada pela autora (2021)

Para expor o *hardware*, esquentamos um canto da tomada e empurramos, até abertura, a tampa. Com isso obtemos uma visão clara de cima, mas um acesso limitado à parte de baixo.

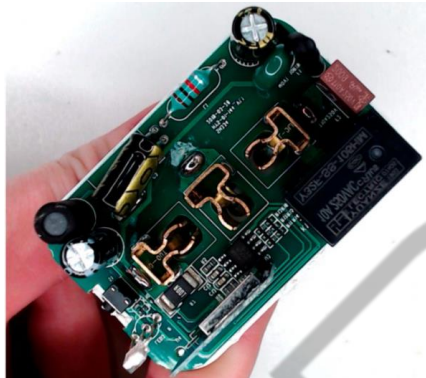


Figura 9 - Visão superior da PCB
Fonte: Elaborada pela autora (2021)

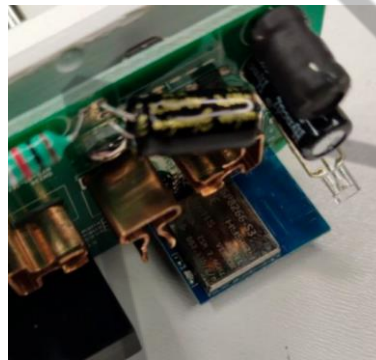


Figura 10 - Visão do ESP8266 pela PCB
Fonte: Elaborada pela autora (2021)



Figura 11 - Identificando as portas de acesso ao ESP8266
Fonte: Elaborada pela autora (2021)

Você deve ter notado onde o ESP8266 encontra-se, ele destaca-se por estar verticalmente alocado à placa. Embaixo da placa, é possível notar uma série de *pads* conectados ao ESP8266. Para evitar ruídos e termos um fácil acesso para soldagem, vamos remover a placa ESP8266 da PCB.



Figura 12 - Visão frontal e traseira do ESP8266
Fonte: Elaborada pela autora (2021)

Utilizando o *datasheet*, vamos identificar esses pinos.

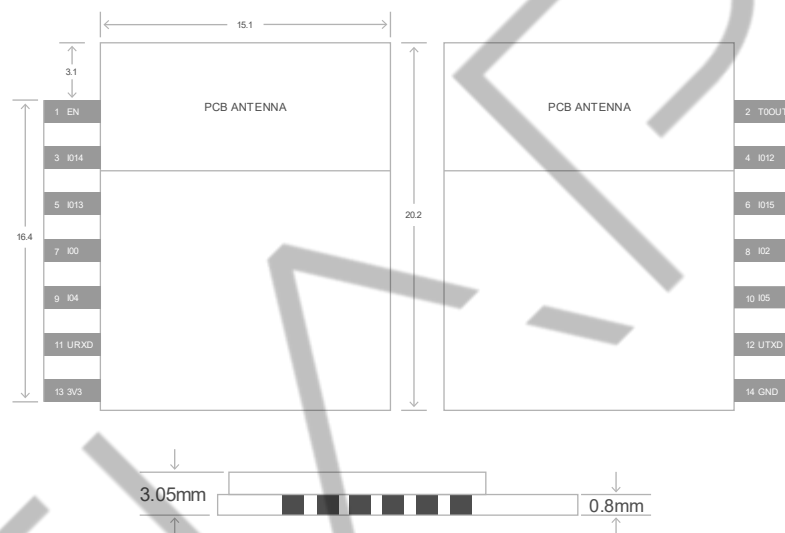


Figura 13 – Pinos do ESP8266
Fonte: Elaborada pela autora (2021)

Vemos, então, que o pino 12 é o TX, ou seja, transmissor da comunicação.

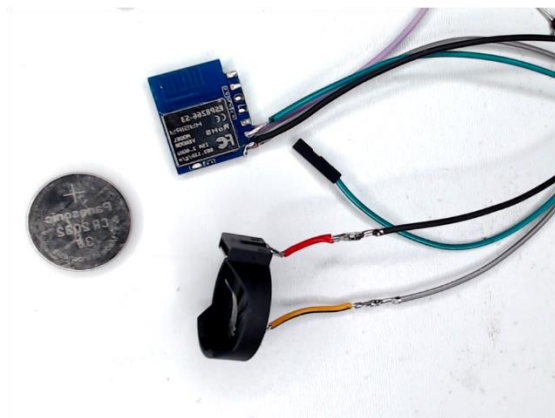


Figura 14 - Soldando os pinos do ESP8266 frontal
Fonte: Elaborada pela autora (2021)



Figura 15 - Soldando os pinos traseiros do ESP8266
Fonte: Elaborada pela autora (2021)

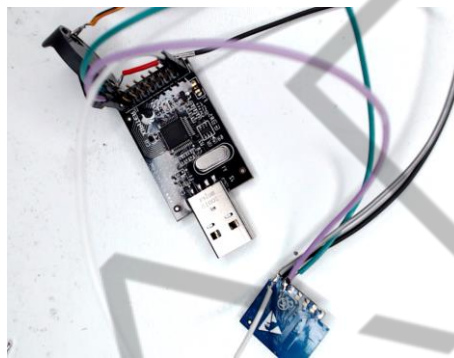


Figura 16 - Ligando os fios ao *the Shikra* para *dump* de *firmware*
Fonte: Elaborada pela autora (2021)

A partir desse momento, podemos realizar o *dump* do firmware utilizando o *the Shikra*, e estamos focando na área de *hardware*, vou deixar que você use dos seus conhecimentos adquiridos para conseguir acesso ao código.

CONCLUSÃO

Com o conteúdo deste capítulo, finalizamos o estudo básico de IoT *Security* e *Hardware hacking*. Para continuar a sua jornada de estudos, não economize em praticar, abrir dispositivos e procurar entender de forma completa todo universo que engloba um dispositivo em si. Jogue CTFs como o Microcorruption e HackTheBox, faça seus próprios códigos vulneráveis e explore-os, leia o código fonte das bibliotecas que for utilizar e tente sempre olhar com uma visão de segurança. E se eu alterar o valor dessa variável? E se trocar esse valor por esse? A malícia e a curiosidade são as maiores ferramentas do *hardware hacker*, use-as sem moderação!

REFERÊNCIAS

ESPRESSIF. **ESP8266 Datasheet.** 2020. Disponível em: <https://www.espressif.com/sites/default/files/documentation/0a-esp8266ex_datasheet_en.pdf>. Acesso em: 8 set. 2021.

ESPRESSIF. **ESP8266.** 2021. Disponível em: <<https://www.espressif.com/en/products/socs/esp8266>>. Acesso em: 8 set. 2021.

XIPITER. **Using The Shikra to Attack Embedded Systems: Getting Started.** 2014. Disponível em: <<https://www.xipiter.com/musings/using-the-shikra-to-attack-embedded-systems-getting-started>>. Acesso em: 8 set. 2021.